



University & Community Federal Credit Union

E-COMMERCE POLICY
ROBERT CLEMENS

Contents

Policy Statement2

Scope.....2

Responsibility2

Perceived threats2

Risk Management3

Monitoring5

Breach of Security6

Contingency Planning/Business Continuity6

Expertise and Training6

UNIVERSITY & COMMUNITY FEDERAL CREDIT UNION ELECTRONIC COMMERCE POLICY

Policy Statement

It is the purpose of this policy to establish guidance on how to identify, measure, monitor, and control risks arising from the use of electronic services. It sets forth the expectations of credit union management and the Board of Directors when implementing and operating e-commerce systems.

Scope

E-commerce refers to computer hardware, software, and telecommunication systems that enable members to access both specific account and general credit union information on products and services and to conduct transactions through a personal computer. The credit union's network design and telecommunication links utilize public networks, i.e., the Internet.

Responsibility

It is the responsibility of the Board of Directors to approve the credit union's written e-commerce policy. Responsibility for development, implementation and maintenance is delegated to the CIO and Information Technology Department. The policy will be reviewed by management and modified if necessary on at least an annual basis to provide for changes in technology, services, and changes in business arrangements.

Perceived threats

- Malicious attacks from hackers
- Virus attacks
- Employee misuse of sensitive information
- Hardware/software failure
- Disasters; i.e., tornado or fire
- Unauthorized use of member's account by another member/person

Risk levels:

Acceptable risk:

- Employee access to systems. Background check on employees. Employees limited to necessary access for job functions.

Managed risk:

- E*teller (cuintouch.com)
- E-mail
- Disasters

- Firewall to limit access,
 - Backups to restore information.
- Eliminated risk:
- Hackers, viruses. Firewall to stop intrusion. Anti-virus software. Intrusion Prevention System to deter malicious attacks and unauthorized use of credit union systems. VPN communications to vendors (Fiserv, TNB, Federal Reserve Bank, Catalyst Corporate)

Risk Management

- A. Safeguarding Member Information – E-commerce systems require effective and reliable controls to maintain data integrity, ensure member privacy and protect the credit union's computer and telecommunications systems from unauthorized intrusion, misuse or fraud. The credit union's security policy provides "end to end" security controls for critical data.
- B. Security Controls - The credit union has developed controls that govern network and data user authentication, transaction verification, data integrity, and virus protection. Periodic assessments are conducted to identify internal and external threats that undermine security and decisions are made based on those findings to modify or add controls. Examples may include viewing virus protection logs and viewing file maintenance reports.
- C. Network and Data Access Controls – The credit union requires verification and enforcement of a user's authorized right to access network, application, and data. The credit union prohibits unauthorized individuals to enter our operations facilities, retrieve confidential information, or to gain access to credit union software applications and operating systems. To enforce access authorization the following controls are used:
 - User IDs
 - Passwords, including regular password updates
 - Member security questions (set by members).
 - Physical control, combination lock, etc., to the computer room
 - Software and hardware security devices, i.e., anti-virus software, firewall, PC, computer control/monitoring software
- D. User Authentication – The credit union will identify the member before issuing authorization codes. Once the member has been identified, the credit union will assign an access code and password. Each time a member attempts to access the e-commerce system, his/her identity is authenticated. Once the authentication has passed, the member can access account information or engage in online transactions.

The credit union does not allow members to complete an application for e-commerce services online. The application process requires the member to know the related account numbers and submit the application either electronically, in person, or by mail. Identity of the applicant is established and verification of the member number is then reviewed before issuing the access

code. An email communication is sent to the member notifying them that their access has been approved as submitted.

E. Member Passwords - If no password is requested, a randomly generated eight-character temporary password is assigned. Members are prompted and required to change the temporary password to their own selection upon their initial access to the system and are required to be changed annually after that time.

- Password Complexity (subject to change as provided by core vendor)
- Based on Fiserv security standards, all new passwords in online banking (going forward) must meet the following requirements:
 - Minimum length: 8.
 - Maximum length: 32 (spaces are allowed, but not at beginning or end of password/ phrase).
 - Must contain at least one upper-case letter.
 - Must contain at least one lower-case letter.
 - Must contain at least one number or one special character.
 - Cannot contain your first or last name.
 - Cannot match the Login ID.
 - Cannot contain the Login ID as part of its makeup.
 - Cannot contain the word "Fiserv" in any upper- and/or lower-case combination.
 - Cannot contain the word "password" as part of its makeup.
 - Cannot contain "5" number of previously used passwords.
- Special Characters Allowed in Passwords
- The following special characters are allowed as part of the overall content of a valid password:
 - ! - The exclamation point.
 - # - The pound/number sign.
 - \$ - The dollar sign.
 - % - The percent sign.
 - _ - The underscore.
 - -- - The dash.

F. Firewalls – Firewalls combine hardware and software to block unwanted communication into and out of the credit union's network while allowing acceptable communications to pass. They provide protection of the internal network and protect all connection points between the internal network and external networks, such as the Internet. The credit union will periodically review and test firewalls. In addition, an independent provider will conduct an annual review and test for intrusion risks.

G. Encryption – Encryption transforms data into readable format. The credit union's system uses TLS connections with up-to-date SSL certificates and underlying ciphers for encryption on all e-commerce system communications. Encryption is used when transmitting all sensitive or critical data. The SSL certificate and TLS protocol undergo at least a yearly test with Qualys SSL Labs to determine the security rating. This test is located at

<https://www.ssllabs.com/ssltest/analyze>. The results are on file with the IT department.

- H. Transaction verification – The credit union’s e-commerce agreements define the procedures for valid and authentic electronic communications between the credit union and its members. The agreements specify that the parties intend to be bound by communications that comply with these procedures. Audit trails are maintained for purposes of identifying the parties that initiate transactions. Audit trails enable the credit union to verify specific transactions and can provide proof of transactions to avoid claims of repudiation by members.
- I. Virus Protection – The credit union has established a credit union-wise detection and prevention program to reduce the likelihood of computer viruses. The program includes end-user policies, training and awareness programs, anti-virus detection tools, and enforcement procedures.

Monitoring

Monitoring is essential for effective e-commerce risk management. Data generated by monitoring techniques allow the credit union to measure performance and assess the effectiveness of security controls.

- A. Security Monitoring – The credit union places a strong emphasis on using monitoring tools to identify vulnerabilities and, in a real-time mode, detect possible intrusions from external and internal parties (hackers). As provided in the credit union’s security policy, staff should report security breaches promptly to appropriate management.
- B. Penetration Testing – Penetration testing is the process of identifying, isolating, and confirming possible flaws in the design and implementation of passwords, firewalls, encryption, and other security controls. Tests simulate the probable actions of unauthorized and authorized users. Because the tactics used by unauthorized users to infiltrate computer systems frequently change, penetration tests do not guarantee that firewalls will prevent all type of attacks. The credit union has contracted with a bonded outside firm that specializes in monitoring security for financial institutions to conduct penetration testing, provide results of those tests, and recommend manual or automated processes to ensure security.
- C. Intrusion Detection – Transaction and audit logs will be produced indicating network traffic on a real-time basis. Systems will be in place to notify the proper parties, or to terminate suspicious network connections. Intrusion detection tools will also enable management to maintain an incident database for trend analysis of network intrusions and attack attempts. Intrusion system is monitored 24/7 by Secure Works security operation center.

Breach of Security

Following the detection of an unauthorized act or user, the credit union will initiate procedures to respond to the intrusion.

- A. Management will be notified immediately regarding the cause and scope of the breach.
- B. The extent of damage or disclosure of information will be determined, including the legal liability the credit union may incur.
- C. Proper response activities will be put in place by the credit union to cover communications with members, law enforcement agencies, regulatory agencies, and the media.
- D. Only designated individuals will be authorized to communicate with any of the above detailed entities.

Contingency Planning/Business Continuity

All e-commerce systems are incorporated into the credit union's overall contingency planning and business continuity efforts. The credit union's core processor and e-commerce provider have each addressed disaster recovery and contingency planning. Similar to other processes and application, the credit union's recovery plan for e-commerce is to be based on a business impact analysis. This analysis should evaluate business applications and processes to determine importance and establish prioritized order of business resumption designed to recover the most critical functions and systems first.

Expertise and Training

The credit union relies on its e-commerce system provider, Fiserv, for all software development and support. The credit union will assess all personnel to determine if special staffing or training needs are required for those involved in systems development, operation, and member support. As deemed appropriate, additional training will be provided. Training needs will be assessed annually to keep pace with technological and personnel changes.